

Northstar Research Portal

CLIENT

Northstar Research Labs (Fictional)

LEAD TESTER

Example Security Team

TARGET / SCOPE

portal.example.test / 192.0.2.0/24

ASSESSMENT PERIOD

2026-09-08 - 2026-09-12

REPORT DATE

2026-09-19

CLASSIFICATION

DEMO - SYNTHETIC DATA

REPORT VERSION

v1.0

1. Executive Summary

This demonstration report presents a fictional external assessment of the Northstar Research Portal. All organizations, systems, accounts, observations, and evidence are synthetic and exist only to illustrate SpectreHUD's Professional Print output.

Findings Matrix

ID	Finding	Severity	Phase	Status
1	Administrative Export Authorization Bypass	CRITICAL	Initial Access & Exploitation	Open
2	Stored Operator Note Injection	HIGH	Initial Access & Exploitation	In Progress
3	Shared Deployment Credential	MEDIUM	Privilege Escalation	Accepted Risk
4	Verbose Build Metadata	LOW	Reconnaissance & Enumeration	Resolved

Total: CRITICAL 1 · HIGH 1 · MEDIUM 1 · LOW 1

- **Initial Access Vector:** An unauthenticated preview route exposed administrative export behavior.
- **Privilege Escalation:** A shared deployment credential expanded access to the background worker.
- **Business Impact & Risk:** A successful chain could expose synthetic research records and alter queued exports.
- **Recommended Remediation:** Enforce server-side authorization, isolate service credentials, and apply contextual output encoding.

2. Scope & Methodology

Testing covered the fictional public portal, its documented API, and one representative worker host. Activities combined authenticated and unauthenticated application testing, configuration review, and controlled validation of the identified attack path.

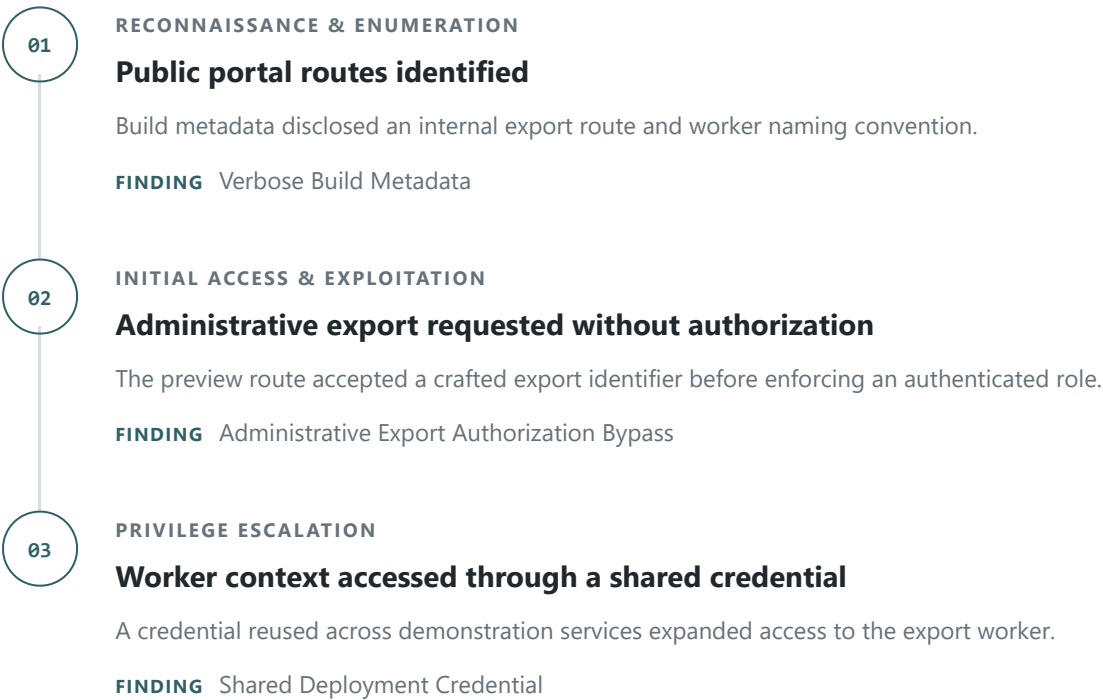
Target	Purpose	Test perspective
portal.example.test	Public research portal	External / unauthenticated
api.portal.example.test	Portal API	External / authenticated
192.0.2.45	Demonstration worker	Internal validation

The example intentionally excludes denial-of-service testing, social engineering, and third-party infrastructure. No real systems were contacted.

3. Attack Path

The demonstration chain shows how individually understandable observations can combine into a material business risk.

Attack Chain



4. Technical Findings

F-001 • Administrative Export Authorization Bypass

CRITICAL

TARGET `api.portal.example.test`, `192.0.2.45` · PHASE Initial Access & Exploitation ·

OBSERVED `2026-09-09 10:24` · CVSS SCORE `9.1` ·

CVSS VECTOR `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N` ·

STATUS Open

DESCRIPTION

The synthetic export-preview endpoint accepted an administrative export identifier before verifying the caller's role. A controlled request returned a demonstration record belonging to another fictional tenant.

```
GET /api/v1/exports/demo-1042/preview HTTP/1.1
Host: api.portal.example.test
Accept: application/json

HTTP/1.1 200 OK
Content-Type: application/json

{"record":"synthetic-study-07","classification":"DEMO"}
```

No bulk extraction was attempted. The response above was sufficient to confirm the missing object-level authorization check.

RECOMMENDATION

Apply deny-by-default authorization to every export operation, verify tenant ownership on the server, and add negative authorization tests for direct object references.

REFERENCES

- OWASP API Security Top 10: Broken Object Level Authorization
- CWE-639: Authorization Bypass Through User-Controlled Key

F-002 • Stored Operator Note Injection

HIGH

TARGET portal.example.test · PHASE Initial Access & Exploitation · OBSERVED 2026-09-09 13:40 ·

CVSS SCORE 8.0 ·

CVSS VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H ·

STATUS In Progress

DESCRIPTION

Operator notes were stored without contextual output encoding. A benign demonstration marker was rendered as markup when an administrator opened the queued export review.

<strong data-demo="synthetic">Review marker

The validation used a non-executable marker and did not attempt session access or browser interaction beyond confirming that stored markup was interpreted.

RECOMMENDATION

Encode untrusted notes for the destination context, enforce a restrictive content security policy, and sanitize previously stored values before displaying them to operators.

REFERENCES

- OWASP Cross Site Scripting Prevention Cheat Sheet
- CWE-79: Improper Neutralization of Input During Web Page Generation

F-003 • Shared Deployment Credential

MEDIUM

TARGET 192.0.2.45 · PHASE Privilege Escalation · OBSERVED 2026-09-10 09:18 · CVSS SCORE 6.5 ·

CVSS VECTOR CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N ·

STATUS Accepted Risk

DESCRIPTION

A fictional deployment credential was shared by two worker services. Compromise of either service would therefore provide unnecessary access to the other's queue. The value itself is intentionally omitted from this public example.

RECOMMENDATION

Issue unique, scoped credentials per service and rotate the shared demonstration value.

F-004 • Verbose Build Metadata

LOW

TARGET portal.example.test • PHASE Reconnaissance & Enumeration •

OBSERVED 2026-09-08 14:05 • CVSS SCORE 3.7 •

CVSS VECTOR CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N •

STATUS Resolved

DESCRIPTION

The public diagnostics response disclosed a build label and an internal worker alias. The information reduced the effort required to identify the synthetic export workflow.

```
{"build":"demo-2026.09","worker":"northstar-export-01"}
```

RECOMMENDATION

Return only a generic health indicator to unauthenticated callers and keep deployment metadata in authenticated operational tooling.

REFERENCES

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

5. Remediation & Action Plan

Address authorization and stored-output handling first, then separate service identities and remove unnecessary diagnostic detail.

Severity	Vulnerability	Recommended Action	Status
<u>CRITICAL</u>	F-001 · Administrative Export Authorization Bypass	Enforce object- and tenant-level authorization on every export route.	Open
<u>HIGH</u>	F-002 · Stored Operator Note Injection	Encode stored notes and deploy a restrictive content security policy.	In Progress
<u>MEDIUM</u>	F-003 · Shared Deployment Credential	Issue scoped per-service credentials and rotate the shared value.	Accepted Risk
<u>LOW</u>	F-004 · Verbose Build Metadata	Keep build and worker identifiers out of public diagnostics.	Resolved

Suggested Validation Sequence

1. Add negative authorization tests for cross-tenant export identifiers.
2. Re-test stored notes in every operator rendering context.
3. Verify each service can access only its own queue and secret.
4. Confirm unauthenticated diagnostics contain no deployment metadata.

APPENDIX

6. Appendix & Evidence

Appendix A: Executed Demonstration Commands

```
curl -sS -H "Accept: application/json" \  
  https://api.portal.example.test/api/v1/exports/demo-1042/preview  
  
curl -sS https://portal.example.test/health
```

Appendix B: Evidence Handling

- All identifiers and responses in this report are synthetic.
- `192.0.2.0/24` is reserved for documentation and examples.
- The `.test` top-level domain is reserved for testing.
- No credentials, customer names, production endpoints, or real assessment data are included.

Appendix C: Report Notice

This file is a product demonstration generated by SpectreHUD. It must not be interpreted as evidence of an assessment against a real organization or system.